

Security+ 2.3 · Mobile Device Vulnerabilities

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.3 — Mobile Device**

Vulnerabilities (3:23) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Celular: jailbreak (iOS) e rooting (Android) ROMPEM a sandbox e tiram proteções do vendor; sideloading = instalar fora da loja (malware). Defesa: MDM (gerencia central), bloquear jailbroken, app store verificado, container (separa trabalho/pessoal).

💡 Highlights que a prova cobra

- Jailbreak/rooting: tirou as proteções do fabricante — risco alto
- MDM: gerencia centralmente apps, config, wipe remotamente

🎯 Dicas de prova & Cenários Típicos

- 'bypasses manufacturer restrictions' = jailbreak/rooting
- 'installing apps outside official store' = sideloading

Cenário clássico de exame: Cenário: 'empresa detecta dispositivo iPhone com jailbreak acessando o email corporativo' — bloquear via MDM.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.3 — Mobile Device Vulnerabilities)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **DLP:** Data Loss Prevention: Ferramenta técnica que monitora, detecta e bloqueia a exfiltração não autorizada de dados sensíveis (CPF, cartões, propriedade intelectual) em repouso, trânsito ou uso.
- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.
Tente responder antes de olhar.

1. Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:

- A)** DLP (Data Loss Prevention)
- B)** SSO
- C)** MFA
- D)** VPN

2. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Jailbreak/rooting: tirou as proteções do fabricante — risco alto'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Jailbreak/rooting: tirou as proteções do fabricante — risco alto...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'MDM: gerencio centralmente apps, config, wipe remotamente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: MDM: gerencio centralmente apps, config, wipe remotamente...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'bypasses manufacturer restrictions' = jailbreak/rooting'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'bypasses manufacturer restrictions' = jailbreak/rooting...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'installing apps outside official store' = sideloading'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'installing apps outside official store' = sideloading...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'empresa detecta dispositivo iPhone com jailbreak acessando o email corporativo' — bloquear via MDM.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'empresa detecta dispositivo iPhone com jailbreak acessando o email...

7. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Jailbreak/rooting: tirou as proteções do fabricante — risco alto'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Jailbreak/rooting: tirou as proteções do fabricante — risco alto...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'MDM: gerencio centralmente apps, config, wipe remotamente'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: MDM: gerencio centralmente apps, config, wipe remotamente...

9. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: '"bypasses manufacturer restrictions' = jailbreak/rooting'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'bypasses manufacturer restrictions' = jailbreak/rooting...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Mobile Device Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: '"installing apps outside official store' = sideloading'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'installing apps outside official store' = sideloading...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — DLP (Data Loss Prevention).

✓ **Por que está certa:** DLP (Data Loss Prevention) é um conjunto de tecnologias e políticas que visam impedir a exfiltração de dados confidenciais, monitorando e controlando transferências de informações sensíveis. No CompTIA Security+ (SY0-701), o DLP é apresentado como um controle que pode bloquear o envio de dados para fora da organização, seja por e-mail, web, USB ou outros canais. O enunciado descreve exatamente um controle que impede um funcionário de enviar uma planilha confidencial para fora da empresa, o que é a função primária do DLP.

✗ **Por que as outras estão erradas:**

- **SSO:** SSO (Single Sign-On) é um mecanismo de autenticação que permite ao usuário acessar múltiplos sistemas com uma única credencial. Ele não controla a transferência de dados ou impede a exfiltração de informações. Portanto, não se aplica ao cenário descrito.
- **MFA:** MFA (Multi-Factor Authentication) é um método de autenticação que exige dois ou mais fatores de verificação para conceder acesso. Ele fortalece a autenticação, mas não impede que um usuário autorizado envie dados confidenciais para fora. Não é um controle de prevenção de perda de dados. Logo, não é a resposta correta.
- **VPN:** VPN (Virtual Private Network) é uma tecnologia que cria um túnel criptografado para comunicação segura, mas não tem a função de inspecionar ou bloquear a transferência de dados confidenciais. Ela protege a transmissão, mas não impede a exfiltração por um usuário autorizado. Portanto, não atende ao requisito do enunciado.

2) C — Implementar a solução correspondente: Jailbreak/rooting: tirou as proteções do fabricante — risco alto....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): Jailbreak/rooting: tirou as proteções do fabricante — risco alto.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) A — Implementar a solução correspondente: MDM: gerencio centralmente apps, config, wipe remotamente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): MDM: gerencio centralmente apps, config, wipe remotamente.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: 'bypasses manufacturer restrictions' = jailbreak/rooting....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): 'bypasses manufacturer restrictions' = jailbreak/rooting.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: 'installing apps outside official store' = sideloading....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): 'installing apps outside official store' = sideloading.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Cenário: 'empresa detecta dispositivo iPhone com jailbreak acessando o email....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): Cenário: 'empresa detecta dispositivo iPhone com jailbreak acessando o email corporativo' — bloquear via MDM..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: Jailbreak/rooting: tirou as proteções do fabricante — risco alto....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): Jailbreak/rooting: tirou as proteções do fabricante — risco alto.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: MDM: gerencio centralmente apps, config, wipe remotamente....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): MDM: gerencio centralmente apps, config, wipe remotamente.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'bypasses manufacturer restrictions' = jailbreak/rooting....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): 'bypasses manufacturer restrictions' = jailbreak/rooting.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: 'installing apps outside official store' = sideloading....

✅ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Mobile Device Vulnerabilities): 'installing apps outside official store' = sideloading.

❌ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.